PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Sauvegarde des SI

03-310 ANSSI - Sauvegarde des systèmes d'information — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. L'attaquant cherche à chiffrer ou effacer l'infrastructure de sauvegarde pour maximiser ses chances d'obtenir une rançon.
2. La règle 3-2-1 impose la conservation de trois copies distinctes dont au moins une hors ligne.
3. La remédiation après incident nécessite une réinstallation depuis des sources de confiance plutôt qu'une simple restauration aveugle.

Contexte et périmètre de la sauvegarde

Notion	À retenir
Menace rançongiciels	L'attaquant tente de **chiffrer**, **effacer** ou **rendre indisponible** l'infrastructure de sauvegarde pour augmenter ses chances d'obtenir une **rançon**. (et ralentir la reconstruction du SI).
Composants et exclusions	Composants : **catalogue/index**, **agent logiciel**, **serveur de sauvegarde**, **support**. Non couverts : **PDMA < 24h** (réplication) ou **archivage légal** avec authenticité.

Architecture de l'infrastructure de sauvegarde

Notion	À retenir
Cloisonnement	Serveurs dans le **SI d'administration** ou une zone distincte ; flux dans un **VLAN dédié** ; **une instance et un magasin par niveau de sensibilité**.
Authentification et flux	Hors **domaine Windows de production** ; filtrage strict par **pare-feu interne** ; flux **à l'initiative du serveur** ; infrastructure obsolète conservée **hors ligne**.

Synthèse des opérations de sauvegarde

Notion	À retenir
Règle 3-2-1 et comptes	Appliquer la règle **3-2-1** avec sauvegarde **hors ligne** indispensable (**bande magnétique** : le plus efficace). Comptes **dédiés et nominatifs** (RBAC) ; privilèges des agents réduits au **strict minimum**.
Restrictions et mises à jour	Pas de sauvegarde/restauration lancée par les utilisateurs (**élévation de privilèges**). **Restauration croisée** désactivée par défaut. Mise à jour proactive (**CVE**, bulletins éditeur).
Contrôle et restauration	Contrôler : comportement inhabituel, volume, lenteurs, politiques. Tester régulièrement avec **procédure rédigée**. En cas d'incident : isoler via **bouton rouge d'urgence**.
Infrastructure et remédiation	Sauvegarder : médias, configurations, binaires, catalogue, matériel secours, clés de chiffrement. Remédiation : réinstaller via **images officielles** et **binaires signés**, contrôler la conformité et scanner les données.

Mesures de protection selon le contexte

Contexte	Mesure de protection
Flux de sauvegarde	Chiffrement et **authentification mutuelle** à l'état de l'art (ex: **TLS**)
Sécurité physique du site de sauvegarde **non satisfaisante**	**Chiffrement systématique** des sauvegardes
Mise au rebut des supports	**Effacement sécurisé**, **zéroïsation** ou **destruction physique**

Virtualisation et Externalisation

Notion	À retenir
Image disque vs Agent	L'**image disque** évite l'accès au contenu si **chiffrée** mais peut gêner le redémarrage d'applications. L'**agent** offre la **granularité** mais augmente la **surface d'attaque**.
Risques externalisés	Vigilance sur la **localisation (UE)**, le **chiffrement propre** avant envoi et la **durée de restauration** compatible avec la **DMIA**. Solution **WORM** moins robuste qu'une solution **hors ligne déconnectée**.

Pièges et confusions

- ⚠ Autoriser les utilisateurs à exécuter eux-mêmes une sauvegarde ou restauration (risque d'élévation de privilèges).
- ⚠ Effectuer une restauration aveugle sans tenir compte du risque d'implants de l'attaquant dans les sauvegardes.
- ⚠ Considérer la solution WORM comme plus robuste qu'une solution hors ligne déconnectée.
- ⚠ Oublier que la restauration croisée doit être désactivée par défaut.

Sigles et définitions

PDMA	perte de données maximale admissible, ou RPO, est la durée maximale de données pouvant être perdues lors d'un incident
DMIA	durée maximale d'interruption admissible, ou RTO, est la durée maximale d'indisponibilité tolérée avant restauration complète du service
Sauvegarde hors ligne	sauvegarde sur un support déconnecté de tout système d'information
Règle 3-2-1	conservation de trois copies distinctes des données, à savoir les données en production et deux sauvegardes sur des supports différents, dont au moins une hors ligne
RBAC	contrôle d'accès basé sur les rôles, permettant de segmenter les rôles des opérateurs de sauvegarde
Restauration croisée	capacité d'une instance de serveur de sauvegarde à restaurer depuis un magasin de données ou un support référencé sur une autre instance
Mode bouton rouge	dispositif d'urgence, script automatisé ou déconnexion physique, permettant d'isoler immédiatement l'infrastructure de sauvegarde
WORM	solution de stockage à écriture unique et lectures multiples, dont le mécanisme d'immuabilité empêche toute modification de la donnée après son écriture

Auto-test

1. Quel est le moyen le plus efficace pour une sauvegarde hors ligne ?
2. Que doit-on faire en cas d'incident pour isoler l'infrastructure ?
3. Quelle fonctionnalité de restauration doit être désactivée par défaut ?
4. Quels cas d'usage la sauvegarde ne couvre-t-elle pas ?
5. Quelle est la mesure de protection si la sécurité physique du site est non satisfaisante ?

Réponses : **1.** La bande magnétique · **2.** Utiliser le mode bouton rouge · **3.** La restauration croisée · **4.** PDMA < 24h ou archivage légal avec authenticité · **5.** Chiffrement systématique des sauvegardes

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.